

This document evaluates SnowBe Online's PCI DSS compliance requirements based on its transaction volume and payment environment. It identifies the appropriate merchant level, outlines the associated compliance obligations, and determines the correct Self-Assessment Questionnaire for the organization.

PCI Audit

Part 1

Group 1

Kayla Hodge
Mark VanDike
Justin Vandrunen
Jarred Ward
Jordan Wicks

1. What PCI merchant level applies to SnowBe Online? Why?

SnowBe Online falls under PCI Merchant Level 2 based on its annual transaction volume, which is the primary factor used to determine merchant classification under PCI DSS. The case study states that the company processes approximately 1,200,000 credit and debit card transactions per year, placing it within the 1 million to 6 million transactions annually range required for Level 2 merchants. This classification is determined strictly by transaction volume, not by company size, revenue, or growth rate. In addition to transaction volume, SnowBe's payment environment further supports this classification because it processes most of its transactions through its AWS-hosted e-commerce website. The company also stores cardholder data directly on its systems, which increases its responsibility for protecting that data. According to PCI DSS, any organization that stores, processes, or transmits cardholder data is fully in scope for compliance requirements. This makes accurate classification especially important, as it determines the level of security controls and validation required.

SnowBe also operates multiple physical storefronts that accept credit card payments using bank-provided terminals, which expands its payment environment beyond just e-commerce. These storefronts introduce an additional payment channel, specifically card-present transactions, alongside its online processing. While the terminals themselves are PCI-compliant, SnowBe is still responsible for overall compliance because it stores and processes cardholder data through its website. This combination of online and in-person transactions creates a more complex cardholder data environment that must be properly secured. The presence of multiple environments handling sensitive data increases both risk and compliance obligations. Overall, PCI Merchant Level 2 is the correct designation because SnowBe's transaction volume clearly falls within the defined threshold, and its operations involve direct handling of cardholder data. This classification accurately reflects both the scale of transactions and the level of risk associated with its data handling practices.

2. What is required under this level?

As a PCI Merchant Level 2 organization, SnowBe Online is required to validate its PCI DSS compliance on an annual basis. This is typically achieved by completing the appropriate Self-Assessment Questionnaire (SAQ) and submitting an Attestation of Compliance (AOC) to formally confirm that all applicable requirements are being met. While Level 2 merchants generally are not required to undergo a full on-site audit, a payment brand or acquiring bank may still require one depending on risk factors or previous compliance issues. In addition to annual validation, SnowBe must conduct quarterly external vulnerability scans performed by an Approved Scanning Vendor (ASV). These scans are critical because SnowBe operates a public-facing e-commerce website, which increases its exposure to external threats and potential attacks. Regular scanning helps identify vulnerabilities before they can be exploited. Together, these requirements ensure that SnowBe maintains a consistent level of external security monitoring.

Beyond validation activities, SnowBe is required to implement and continuously maintain all 12 PCI DSS control requirements across its environment. These controls are designed to protect cardholder data and include securing networks, protecting stored data, encrypting data in transit, maintaining vulnerability management programs, enforcing strong access controls, and regularly monitoring and testing systems. PCI DSS applies to any organization that stores, processes, or transmits cardholder data, which directly applies to SnowBe's operations. Because SnowBe stores cardholder data on its website and processes over one million transactions annually, its compliance scope is both broad and complex. The company must ensure that all systems within its cardholder data environment are properly secured and included in its compliance efforts. This includes both its AWS-hosted systems and any supporting internal infrastructure. These requirements ensure that SnowBe not only completes annual validation but also maintains continuous protection of sensitive payment data across all systems and locations.

3. Which SAQ(s) applies to SnowBe Online? Why? Be thorough in your explanation.

The appropriate Self-Assessment Questionnaire for SnowBe Online is SAQ D for Merchants. This is because SnowBe stores, processes, and transmits cardholder data within its own environment, which places it outside the eligibility criteria for all simplified SAQ types. SAQ D is specifically intended for merchants with complex environments or those that do not fully outsource payment processing, and it requires validation against all applicable PCI DSS requirements. SnowBe does not qualify for SAQ A because it does not fully outsource payment processing to a third-party provider. Instead, the company uses a WordPress shopping cart hosted on its own AWS environment, meaning cardholder data is handled directly by SnowBe systems. Additionally, SnowBe stores cardholder data on its website, which automatically disqualifies it from SAQ types designed for merchants that do not store sensitive data. Because of this, SnowBe must complete a full assessment rather than a reduced-scope questionnaire.

SnowBe also does not qualify for SAQ C or other reduced-scope SAQs, which are intended for merchants with more limited or segmented payment environments. In contrast, SnowBe's environment includes multiple interconnected systems such as web servers, internal servers, VPN-connected laptops, and access management systems. This interconnected structure expands the scope of the cardholder data environment and requires a more comprehensive assessment. Although SnowBe operates physical storefronts, those transactions are processed using bank-provided, PCI-compliant terminals that do not store customer data within SnowBe's systems. Because these devices are externally managed and do not introduce additional storage or processing into SnowBe's environment, they do not require a separate SAQ. For these reasons, SAQ D is the only appropriate option, as it fully covers SnowBe's e-commerce operations, internal systems, and storage of cardholder data. This ensures that all relevant systems and processes are properly evaluated against PCI DSS requirements.

4. What else, if anything, is required based on the SAQ requirement? IF nothing, be sure to state that. Be thorough in your explanation.

There are additional requirements associated with completing SAQ D, so it is not limited to simply answering the questionnaire. In addition to completing the SAQ, SnowBe must submit an Attestation of Compliance (AOC), which formally confirms that the organization has assessed its environment and meets applicable PCI DSS requirements. SnowBe is also required to ensure that its cardholder data environment is properly defined and scoped before completing the SAQ. This includes identifying all systems, networks, and processes that store, process, or transmit cardholder data and ensuring they are included in the assessment. Without proper scoping, the SAQ would not be considered valid or complete. In addition, SnowBe must provide supporting evidence of compliance when required, such as quarterly external vulnerability scan results from an Approved Scanning Vendor. The company must also maintain documentation showing that required security controls are implemented and actively maintained.

If any SAQ responses indicate that a requirement is not met, SnowBe must develop a remediation action plan that outlines how and when those gaps will be addressed. This ensures that deficiencies are tracked and resolved in a structured and accountable manner. Completing SAQ D also requires SnowBe to validate compliance against all applicable PCI DSS requirements, not just a limited subset, making the process more comprehensive. This includes evaluating security controls across all systems within the cardholder data environment. Maintaining compliance is not a one-time activity, and SnowBe must continuously monitor, update, and improve its security controls. Ongoing efforts are necessary to ensure the protection of cardholder data and readiness for future assessments. These requirements ensure that completing SAQ D reflects a full evaluation of the organization's security posture rather than a simple checklist exercise.

5. Statement of Agreement for the SAQ group portion.

We, Kayla Hodge, Mark VanDike, Justin Vandrunen, Jarred Ward, and Jordan Wicks agree with the information that is in our group SAQ and agree to accept the grade that our group receives.